

TraceVIC: Causal Reasoning over Code Evolution for Identifying Vulnerability-Inducing Commits

Fnu Tanish
Northern Illinois University
ttanish1@niu.edu

Samiha Shimmi
Northern Illinois University
sshimmi@niu.edu

Samikshya Chapagain
Northern Illinois University
schapagain2@niu.edu

Hamed Okhravi
MIT Lincoln Laboratory
hamed.okhravi@ll.mit.edu

Mona Rahimi
Northern Illinois University
rahimi@cs.niu.edu

Lei Zhang
Northern Illinois University
zhanglei@niu.edu

Abstract

Software vulnerabilities are often discovered long after they are introduced, making it difficult to identify the vulnerability-inducing commit (VIC) responsible for introducing the underlying vulnerable condition. Existing VIC identification techniques largely rely on `git blame` to trace vulnerable code through revision history and use positional heuristics, such as selecting its earliest or most recent modification. However, the true VIC may occur anywhere within this history, and vulnerable behavior may depend on code that evolves across multiple revisions. We therefore argue that VIC identification requires reasoning about *how* vulnerability-relevant code evolves, rather than simply *where* a candidate commit appears in the revision history.

We present *TraceVIC*, a temporal graph-based approach for identifying and ranking VICs by reasoning over code evolution. *TraceVIC* first localizes likely root-cause lines and traces their histories across revisions, constructing graph representations that capture program structure within each revision and the evolution of vulnerability-relevant code across the history. It reasons over the resulting revision history, using temporal edges to preserve correspondences between program elements across consecutive revisions, and directly ranks candidate commits according to their contribution to the vulnerable condition.

Ablation results show that modeling the full revision history improves F2 from 0.637 to 0.814. *TraceVIC* improves F2 by up to 28.7% over state-of-the-art methods and identifies a valid VIC for 78 of 79 vulnerabilities across four unseen C/C++ projects.

1 Introduction

Identifying Vulnerability-Inducing Commits (VICs) is fundamental to understanding how software vulnerabilities originate and supporting downstream tasks such as vulnerability remediation, affected-version identification, and learning-based vulnerability detection. Yet, vulnerabilities are rarely discovered when introduced [12, 21, 36]; empirical studies show

that they persist in codebases for an average of 1,732 days before being patched [1]. Consequently, the commit that originally introduced the vulnerable condition—the VIC—often remains unknown [16, 32]. Incorrectly attributing the origin of a vulnerability can lead to incomplete fixes [24, 27], inaccurate affected-version information in vulnerability databases such as NVD [30], and noisy labels in datasets used to train vulnerability detection and mining models [9, 33].

Prior work identifies VICs by tracing vulnerability-relevant code backward through revision history, typically using `git blame` or similar line-level history analysis [5, 44]. The most widely used approach, SZZ [40], starts from lines deleted by a vulnerability-fixing commit (VFC) and attributes them to the *most recent* commits that previously modified those lines. However, SZZ was originally developed for general defects rather than security vulnerabilities. Unlike general defects, vulnerabilities can remain latent for extended periods; empirical studies report that more than 50% of them are foundational, persisting across multiple software versions before they are discovered [34, 36]. Consequently, in the context of code vulnerabilities, the most recent modification of vulnerable code does not necessarily correspond to the commit that introduced the vulnerable condition.

Variants of SZZ such as V-SZZ [4] address this limitation by tracing vulnerable lines backward and selecting their *earliest* modification. Yet both strategies rely on a positional assumption: the VIC is determined by *where* a candidate appears in the revision history—for example, the latest or earliest modification—rather than by whether its change actually introduced the vulnerable condition [5, 6, 31]. This assumption becomes particularly problematic when vulnerable behavior emerges as code evolves across multiple revisions. In such cases, the true VIC may be the earliest, latest, or an intermediate modification, and there is no principled way to determine the correct position a priori. Positional heuristics can therefore miss the true origin of vulnerabilities whose relevant code evolves through multiple revisions before fix [17, 28, 38].

More recent learning-based SZZ variants improve the analysis of individual code changes but do not fully overcome

this limitation. For example, NeuralSZZ [41] uses graph neural networks to model relationships among changes within a fixing commit, yet its analysis remains confined to a single revision [9, 23].

Similarly, LLM-SZZ [13] uses large language models to improve root-cause line selection while tracing revisions backward, but ultimately relies on V-SZZ’s positional stopping criterion to identify the inducing commit. Thus, despite increasingly sophisticated analysis, existing approaches do not explicitly reason about **how** the vulnerable condition develops across the sequence of code revisions [8, 38].

In practice, vulnerabilities arise within evolving program states [6, 47]. A change may introduce a vulnerable condition, subsequent revisions may preserve, transform, or propagate it, and later changes may expose or eventually repair it [25, 34, 35, 48]. Identifying the VIC therefore requires reasoning not only about individual revisions, but also about how vulnerability-relevant code evolves across the revision history.

In this paper, we formulate VIC identification as reasoning over evolving program states. Rather than identifying a commit based on its position in the revision history, our goal is to determine which change most strongly contributed to the emergence of the vulnerable condition. This requires reasoning about **what** changes across revisions and **how** vulnerability-relevant code persists or transforms throughout its evolution history. We refer to this formulation as *contribution-based identification over code evolution*: candidate commits are evaluated according to their contribution to the vulnerable condition rather than their temporal position.

We operationalize this formulation through TraceVIC, a temporal graph-based framework for identifying and ranking VICs. TraceVIC models vulnerability-relevant code across its revision history rather than from a single program snapshot. Starting from the fixing commit, it traces relevant code through prior revisions and constructs a sequence of graph representations that capture the structural and semantic relationships within each revision. TraceVIC then connects corresponding code elements across revisions through temporal edges, representing how the code evolves over time. A graph-based architecture reasons over this evolution to first rank likely root-cause lines and then rank candidate commits according to their contribution to the vulnerability. This enables TraceVIC to identify the VIC without assuming that it occurs at a predefined position in the revision history.

This formulation introduces two challenges: capturing vulnerability-relevant information across multiple revisions while preserving both within-revision program structure and cross-revision evolution, and distinguishing changes that contribute to the vulnerable condition from those that merely precede or follow it. TraceVIC addresses these challenges by jointly modeling revision-level program structure, cross-revision evolution, and commit-level relationships.

We investigate the following research questions:

- **RQ1:** How does reasoning over code evolution improve

VIC identification, and which components contribute to its effectiveness?

- **RQ2:** How well does TraceVIC generalize across projects?

An ablation study confirms that the primary benefit comes from reasoning over the full revision history, increasing F2 from 0.637 to 0.814 compared with single-revision analysis; explicit cross-revision correspondences provide an additional recall-oriented improvement.

We evaluate TraceVIC on manually validated vulnerabilities from the Linux kernel against state-of-the-art retrieval-, selection-, and ranking-based VIC identification methods. At top-3, TraceVIC improves F2 by 23.1%, 17.3%, and 28.7% over the strongest retrieval-, selection-, and ranking-based baselines, respectively.

We further evaluate TraceVIC on 79 vulnerabilities from four unseen C/C++ projects—FFmpeg, ImageMagick, OpenSSL, and PHP-SRC. Without training on these projects, TraceVIC identifies at least one valid VIC for **78 of 79 vulnerabilities** and achieves an overall precision of **0.855**, recall of **0.839**, F1 of **0.847**, and F2 of **0.842**. Compared with the strongest baseline on this dataset (F1=0.700), TraceVIC improves F1 by **21.0%**. These results demonstrate that reasoning over temporal code evolution provides consistent improvements over existing VIC identification formulations and generalizes beyond the project used for training.

In summary, this paper makes the following contributions:

- **Evolution-Aware VIC Formulation.** We formulate VIC identification as contribution-based reasoning over evolving program states, moving beyond approaches that attribute vulnerabilities using fixed positional heuristics.
- **Temporal Graph-Based VIC Identification.** We introduce *TraceVIC*, a framework that represents vulnerability-relevant code across multiple revisions and augments revision-level program graphs with explicit correspondences between program elements across consecutive revisions. TraceVIC uses these representations to localize root-cause lines and directly rank candidate VICs.
- **Comprehensive Empirical Evaluation.** We evaluate TraceVIC against state-of-the-art retrieval-, selection-, and ranking-based VIC identification methods, isolate the contributions of temporal modeling through ablations, and evaluate generalization across four unseen C/C++ projects.

In this paper, we focus on vulnerabilities in C/C++ systems, where low-level memory and pointer operations make accurate vulnerability attribution particularly challenging. All code, trained models, datasets, and scripts required to reproduce our results are publicly available in our repository.¹

¹public repository: <https://anonymous.4open.science/r/TraceVIC/>

2 A Motivating Example for CVE-2014-2309: Why Positional Reasoning Fails?

Existing SZZ-based approaches trace vulnerability-relevant code through revision history and identify VICs using positional heuristics, typically selecting the most recent (B-SZZ) or earliest (V-SZZ) modification [4, 38, 40]. However, vulnerable code may evolve across multiple revisions, and the true VIC can occur anywhere in this history [2, 37].



Figure 1: Vulnerability-Inducing Commit occurring at a middle position (CVE-2014-2309) in the history chain.

We illustrate this limitation using CVE-2014-2309, a real world Linux kernel vulnerability that allows a remote attacker to exhaust system memory through unbounded allocation of routing entries. Figure 1 shows the evolution of the relevant `ip6_dst_alloc` call across several revisions.

Early commits establish and extend the basic allocation logic without introducing unsafe behavior. A later commit, 957c665, introduces the semantic change that enables route entries to bypass the relevant accounting mechanism, creating the vulnerable condition. Subsequent commits preserve and further evolve this behavior before the vulnerability is eventually fixed. Thus, the ground-truth VIC occurs in the middle of the revision history rather than at either boundary.

A positional method can therefore select the wrong commit even when it correctly traces the relevant code history. B-SZZ

favors a later modification, while V-SZZ favors an earlier one; neither evaluates which candidate change most strongly corresponds to the introduction of the vulnerable condition. This motivates formulating VIC identification as a ranking problem over the candidate history: rather than treating all retrieved commits equally or selecting a candidate based on temporal position, the model prioritizes the ground-truth VIC. In this example, the ranking places 957c665 above the other commits in the history because it is the commit that introduced the vulnerable condition.

This example motivates treating VIC identification as attribution over code evolution rather than positional selection. A method must therefore reason over the sequence of vulnerability-relevant program states and identify which change introduced the vulnerable condition.

3 Problem Formulation

This section formalizes the problem of VIC identification:

Vulnerability-fixing commit (VFC): A fixing commit V modifies one or more source files to resolve a reported security vulnerability. Its diff contains deleted lines $\mathcal{D}(V) = \{d_1, \dots, d_m\}$ and added lines $\mathcal{A}(V) = \{a_1, \dots, a_n\}$, where $m + n \geq 1$. We distinguish two types of fixes:

- *Deletion-involving* ($m \geq 1$): the diff removes at least one existing line, including pure deletions, modifications/replacements, or relocations. TraceVIC initiates history tracing from the deleted lines.
- *Addition-only* ($m = 0, n \geq 1$): the diff adds lines without deleting existing ones, leaving no deleted line to trace. TraceVIC uses nearby pre-existing code as anchors.

Anchor-Line Extraction for Addition-Only Fixes: Most SZZ-family methods, except TSE-SZZ, construct VIC candidates by tracing only lines deleted by a fixing commit, based on the assumption that the vulnerability originated only from code removed by the fix. However, some vulnerabilities are repaired entirely by adding previously missing code, leaving no deleted line to trace. In our dataset, 183 of 755 cases (24.2%) are such addition-only fixes, for which $\mathcal{D}(V) = \emptyset$. Conventional deletion-based tracing therefore produces no VIC candidates for these cases.

TraceVIC handles these cases through *anchor-line extraction*. Although the lines added by the fix did not exist in the pre-fix revision and therefore cannot be traced backward, the existing lines surrounding the insertion point can be traced through revision history. TraceVIC therefore uses pre-existing code around the insertion point as anchors for locating the vulnerability-relevant revision history. These anchors are used only to initiate history tracing; the commits to which they trace are subsequently evaluated and ranked by TraceVIC rather than being directly treated as VICs.

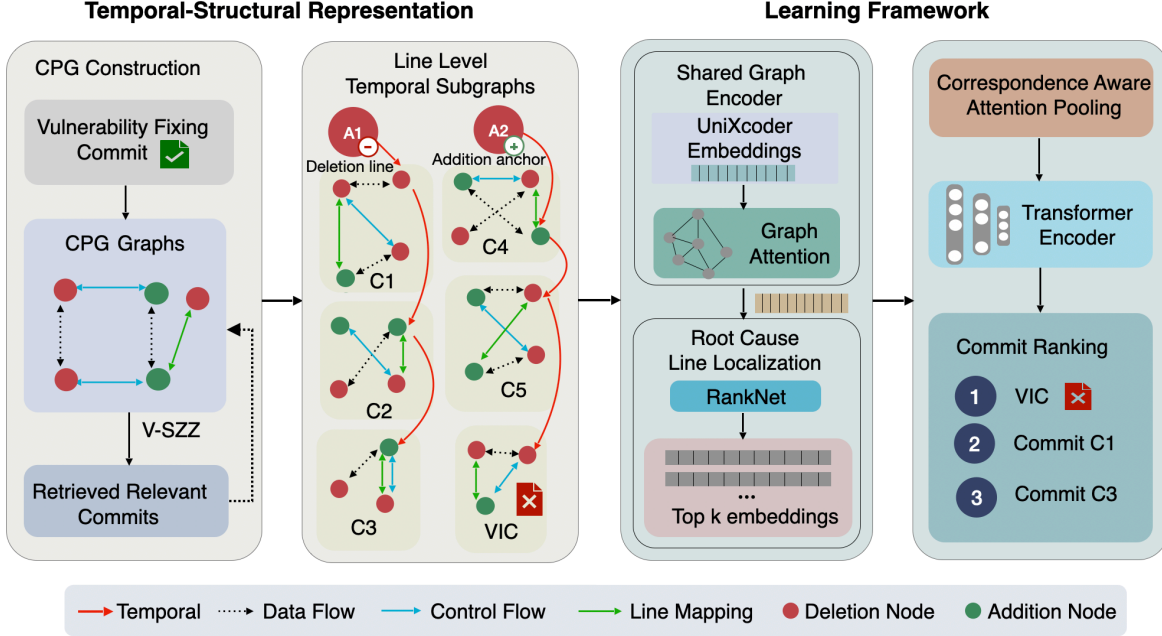


Figure 2: Overview of TraceVIC. TraceVIC constructs temporal Code Property Graphs (CPGs) over candidate commit histories, encodes structural and evolutionary relationships to localize root-cause lines, and aggregates the selected representations to rank candidate VICs.

For each contiguous block of added lines, TraceVIC extracts up to three anchors from the pre-fix revision: the nearest meaningful lines above and below the insertion and the enclosing function signature. Structural boilerplate and simple error-handling statements are filtered to avoid uninformative anchors. Each anchor independently initializes the same history-tracing procedure used for deleted lines, and the resulting candidate histories are subsequently evaluated.

Multiple anchor types are extracted because no single neighbouring line is reliable across fixes. Which anchor reaches the inducing commit depends on the structure of the defect: for a missing guard, the operation requiring protection may sit either above or below the inserted check, and only one of the two may carry the relevant history; for a missing cleanup, the acquisition of the leaked resource typically precedes the insertion. Extracting complementary anchors and filtering uninformative ones therefore recovers the vulnerability-relevant history in cases where any individual anchor would fail. Appendix G details the extraction procedure and traces three addition-only CVE fixes through it, including one in which the resulting attribution independently matches the kernel maintainers’ own `Fixes`: tag.

Throughout the remainder of the paper, we use $\mathcal{L}(V)$ to denote the set of lines used to initiate history tracing:

$$\mathcal{L}(V) = \begin{cases} \mathcal{D}(V), & \mathcal{D}(V) \neq \emptyset, \\ \mathcal{A}(V) = H(V), & \mathcal{D}(V) = \emptyset, \end{cases} \quad (1)$$

where $\mathcal{H}(V)$ denotes the extracted anchor set. Each $l_i \in \mathcal{L}(V)$ is processed through the same candidate-chain and temporal-graph construction pipeline. Additional details and examples of anchor extraction are provided in Appendix G.

Candidate Commit Chain: For each line $l_i \in \mathcal{L}(V)$, we trace its modification history backward through the repository, yielding a *candidate commit chain*:

$$\mathcal{C}^{(i)} = \langle c_1^{(i)}, c_2^{(i)}, \dots, c_{n_i}^{(i)} \rangle \quad (2)$$

where $c_1^{(i)}$ is the most recent commit that modified l_i prior to the fix, and $c_{n_i}^{(i)}$ is the earliest traceable modification. Since a single commit may modify multiple lines, it can appear in more than one candidate chain. To preserve the per-chain context of each occurrence, the overall *candidate set* is defined as the multiset union of all chains:

$$\mathcal{C}(V) = \biguplus_{i=1}^m \mathcal{C}^{(i)}, \quad (3)$$

where $\biguplus$ denotes multiset union and m is number of traced lines. Each element in $\mathcal{C}(V)$ is thus a tuple (c, i) , representing commit c in the context of chain $\mathcal{C}^{(i)}$.

For addition-only commits, each anchor line is emitted as a synthetic deletion line, so the chain construction above applies uniformly.

Vulnerability-inducing Commit (VIC): We define the VIC as the commit that introduces or modifies the program semantics that create the vulnerable condition addressed by the VFC. A later commit that merely exposes an existing vulnerability, or an earlier commit that introduces code subsequently involved in the vulnerability without creating the vulnerable condition, is therefore not considered the VIC. A VIC must therefore contributed in creating the vulnerability; merely modifying code that is later involved in the vulnerability is insufficient. We follow the expert-validated ground truth in the benchmark dataset.

VIC Identification: We formulate VIC identification problem as a **commit ranking problem**:

Given: a vulnerability-fixing commit V , its traced lines $\mathcal{L}(V) = \{l_1, \dots, l_m\}$, and the corresponding candidate commit chains $\{\mathcal{C}^{(i)}\}_{i=1}^m$. **Goal:** learn a scoring function $f(c, i) = f(c \mid \mathcal{C}^{(i)})$ over each tuple $(c, i) \in \mathcal{C}(V)$. The final score for a commit c is aggregated across all chains in which it appears:

$$\hat{f}(c) = \max_{i: c \in \mathcal{C}^{(i)}} f(c \mid \mathcal{C}^{(i)}) \quad (4)$$

such that $\hat{f}(c^*) > \hat{f}(c)$ for all $c \in \mathcal{C}(V) \setminus \{c^*\}$, where c^* is the true VIC, identified as $c^* = \arg \max_{c \in \mathcal{C}(V)} \hat{f}(c)$.

The key distinction between TraceVIC and prior work lies in how this function f is defined. Existing SZZ-based methods implicitly reduce f to a deterministic positional rule:

$$c_{\text{B-SZZ}}^* = c_1, \quad c_{\text{V-SZZ}}^* = c_n \quad (5)$$

where c_1 is the most recent and c_n the earliest commit in a candidate chain. In both cases, the inducing commit is selected based solely on its position, without considering the semantic content of changes.

Unlike positional approaches, TraceVIC learns f over temporal-structural representations of candidate commits and identifies the VIC as $\arg \max_{c \in \mathcal{C}(V)} f(c)$. These representations capture both the properties of vulnerability-relevant code within each revision and its evolution across revisions, allowing the ground-truth VIC (c^*) to receive the highest score regardless of its position in the candidate history. Although TraceVIC uses positional encodings to preserve the ordering of revisions, its ranking objective does not impose a predefined positional rule, such as selecting the earliest or most recent modification. Thus, temporal position provides evolutionary context rather than determining the VIC directly.

This ranking formulation differs from prior learning-based approaches in both the information considered and how the final VIC is identified. NeuralSZZ analyzes code changes within individual revisions, whereas LLM-SZZ improves semantic reasoning over vulnerability-relevant lines but ultimately relies on V-SZZ’s positional stopping criterion. In contrast, TraceVIC jointly reasons over the evolution of code

across multiple revisions and directly ranks candidate commits without assuming that the VIC occurs at a predefined temporal position.

TraceVIC operationalizes our formulation through two key components: (i) a temporal-structural representation that captures vulnerability-relevant code and its evolution across revisions, and (ii) a ranking objective that evaluates candidate commits using this representation.

4 Temporal-Structural Representation

Given a vulnerability-fixing commit V , TraceVIC produces a ranked list of candidate commits, with the highest-scoring candidate identified as the predicted VIC. As shown in Figure 2, the framework consists of *temporal-structural graph construction* followed by two sequential *learning stages*. This section describes the graph construction.

4.1 Revision-Level Structure

For each traced line $l_i \in \mathcal{L}(V)$, TraceVIC retrieves its modification history as a candidate chain $\mathcal{C}^{(i)} = \{c_1, \dots, c_n\}$. TraceVIC identifies the source file containing l_i in the fixing commit and follows that file across the candidate chain. For each commit $c_t \in \mathcal{C}^{(i)}$, it constructs a revision-level Code Property Graph (CPG) $\mathcal{G}_t = (V_t, E_t)$ for that file and then restricts the graph to the code changed by c_t .

Specifically, TraceVIC represents program structure using AST-level units, including functions, control structures, statements, and expressions, as graph nodes. Accurate AST construction for C/C++ requires the compilation context, including headers, macros, and compiler options. TraceVIC therefore reconstructs this context from the project build before parsing the source code. In our implementation, Bear [29] captures the compilation context, which Clang [22] uses to construct the AST.

To capture relationships among these program elements, TraceVIC augments the AST nodes with control- and data-flow dependencies. We use Joern [46] to extract CFG and DFG edges and align them with the AST nodes at the source-line level. After constructing the CPG, TraceVIC retains the AST nodes whose source ranges overlap lines added or deleted by c_t in the traced file, together with the relationships among those nodes. The resulting $\mathcal{G}_t$ therefore captures the structural and flow relationships among the code elements changed by c_t in the file associated with l_i .

4.2 Cross-Revision Node Correspondence

After constructing the revision-level CPGs, TraceVIC identifies the CPG node corresponding to the traced line in each revision and connects these nodes across consecutive revisions. This provides an explicit representation of how the

traced code persists or changes throughout its modification history.

For each pair of consecutive commits (c_t, c_{t+1}) , TraceVIC identifies the CPG node representing the traced code in each revision. Because a CPG node may span multiple source lines, and the traced code may change or shift to a different line number across revisions, TraceVIC uses a three-level matching strategy. It first matches using both source-line range and code prefix. If no match is found, it uses source-line range alone to accommodate changes in code content, and finally code prefix alone to accommodate line-number shifts.

Once the corresponding nodes are identified, TraceVIC connects them with bidirectional temporal edges, allowing information to propagate across revisions in both directions. If the CPG exists but no corresponding node can be identified, no temporal edge is added. If a revision produces an empty CPG, TraceVIC instead creates a synthetic node from the traced history entry to preserve that revision in the evolution sequence. Appendix C provides the complete matching procedure.

4.3 Temporal Subgraph Formation

For each traced line $l_i \in \mathcal{L}(V)$, TraceVIC has a candidate chain $\mathcal{C}^{(i)} = \{c_1, \dots, c_n\}$ and a corresponding revision-level CPG $\mathcal{G}_t = (V_t, E_t)$ for each commit c_t . TraceVIC combines these CPGs into a single temporal subgraph $\mathcal{G}^{(i)}$ by retaining their intra-revision edges and adding the temporal edges established between consecutive revisions:

$$\mathcal{G}^{(i)} = \left(\bigcup_{t=1}^n V_t, \bigcup_{t=1}^n E_t \cup E_{\text{temp}} \right). \quad (6)$$

Within each revision,

$$E_t = E_t^{\text{cfg}} \cup E_t^{\text{dfg}} \cup E_t^{\text{lm}}, \quad (7)$$

where E_t^{cfg} and E_t^{dfg} capture control- and data-flow dependencies, respectively, and E_t^{lm} captures the local structural relationships between AST-level nodes. Across revisions,

$$E_{\text{temp}} = \{(v_t, v_{t+1}), (v_{t+1}, v_t) \mid v_t \leftrightarrow v_{t+1}, t = 1, \dots, n-1\}, \quad (8)$$

where $v_t \leftrightarrow v_{t+1}$ indicates that the two nodes were identified as corresponding program elements using the matching procedure in Section 4.2.

The resulting $\mathcal{G}^{(i)}$ therefore represents the complete history of l_i in a single graph: CFG, DFG, and LINEMAP edges capture relationships within each revision, while temporal edges connect the corresponding code across revisions. These relationships are represented by seven edge types: CFG_FWD/BWD, DFG_FWD/BWD, LINEMAP, and TEMPORAL_FWD/BWD. The graph encoder learns a separate bias for each edge type so that structural and temporal relationships remain distinguishable during message passing.

TraceVIC constructs a separate temporal subgraph $\mathcal{G}^{(i)}$ for each $l_i \in \mathcal{L}(V)$ because different traced lines may follow different modification histories. Within each subgraph, the CPG node corresponding to l_i is assigned index 0, providing a consistent location from which TraceVIC extracts its representation for the subsequent line-level scoring stage.

5 Learning Framework

TraceVIC identifies the VIC through two sequential learning stages that share a common graph encoder. The encoder learns representations of the temporal subgraphs constructed above; it is trained jointly with the first-stage line-ranking task and then frozen for the second-stage commit-ranking task.

5.1 Shared Graph Encoder

For each temporal subgraph $\mathcal{G}^{(i)}$, TraceVIC initializes each node v with a UniXcoder [15] embedding $\mathbf{x}_v \in \mathbb{R}^{d_u}$ of the code element represented by that node. The embedding is projected to the encoder dimension d and combined with a fixed sinusoidal positional encoding (PE) of the same dimension:

$$\mathbf{h}_v = \text{Proj}(\mathbf{x}_v) + \text{PE}(\text{pos}(v)), \quad \mathbf{h}_v \in \mathbb{R}^d, \quad (9)$$

where h_v is the initial representation of node v and $\text{pos}(v) \in \{0, \dots, n-1\}$ denotes the position of the commit containing v in the candidate chain. The positional encoding preserves the ordering of revisions as contextual information; it does not impose a rule that the VIC must occur at any particular position.

The initialized node representations are then propagated over the temporal subgraph using edge-aware multi-head graph attention. For each graph edge, the attention score includes a learned bias specific to its edge type and attention head. This allows the encoder to distinguish information propagated through control-flow, data-flow, local structural, and temporal relationships rather than treating all graph connections equivalently. The encoder therefore jointly represents the code associated with each node, its position in the revision sequence, and its structural and temporal relationships with other nodes. Full encoder equations are provided in Appendix E.

5.2 Relevant Line Localization

The first learning stage ranks the traced lines $l_i \in \mathcal{L}(V)$ to identify those whose modification histories are most likely to be relevant to the vulnerability.

Label derivation: Because ground truth is available at the commit level, TraceVIC derives line-level labels from each traced line’s candidate chain. A traced line l_i receives a positive label if its candidate chain $\mathcal{C}^{(i)}$ contains the ground-truth VIC c^* :

$$y_i = \mathbf{1}[c^* \in \mathcal{C}^{(i)}]. \quad (10)$$

Thus, if multiple traced lines lead to candidate chains containing c^* , each receives $y_i = 1$, which means that tracing l_i produces a chain containing the ground-truth VIC.

Line ranking: After encoding each temporal subgraph $\mathcal{G}^{(i)}$, TraceVIC extracts the final representation of its traced-line node (node 0):

$$\mathbf{e}^{(i)} = \mathbf{h}_0^{(L)} \in \mathbb{R}^d, \quad (11)$$

where $\mathbf{h}_0^{(L)}$ is the representation of node 0 after L graph-attention layers, and $\mathbf{e}^{(i)}$ denotes the resulting representation for traced line l_i . At this point, $\mathbf{e}^{(i)}$ captures the code semantics, structural dependencies within revisions, and cross-revision evolution associated with l_i .

A RankNet [7] scoring head assigns a score to each traced-line representation and is trained pairwise to give higher scores to lines whose candidate chains contain the ground-truth VIC than to lines whose chains do not. At inference, lines are ordered by these scores, and the top- k lines are passed to the commit-attribution stage.

5.3 Commit-Level Attribution

The second learning stage determines which candidate commit most strongly contributed to the vulnerable condition. It takes the top- k temporal subgraphs selected by the line-localization stage and leverages their node representations produced by the shared graph encoder, which is frozen during this stage. TraceVIC first aggregates all nodes associated with each commit into a single commit representation. It then models the resulting sequence of commit representations and assigns a score to each candidate commit.

Correspondence-aware attention pooling: For each candidate commit c_t , TraceVIC collects the encoded nodes belonging to c_t across the selected top- k temporal subgraphs. These nodes contain two types of information: (i) *Correspondence nodes* are connected to a corresponding code element in an adjacent revision by a temporal edge and therefore carry information about code evolution, and (ii) *Local nodes* have no such temporal correspondence and capture structural information specific to that revision.

Rather than pooling both types identically, TraceVIC uses attention to learn how strongly each node should contribute to the commit representation. It maintains two learnable query vectors for each attention head h : q_{corr}^h for nodes participating in cross-revision correspondences and q_{local}^h for nodes carrying only revision-local information. For a node v , the query is selected as

$$q_v^h = \begin{cases} q_{\text{corr}}^h, & \text{if } v \text{ participates in a temporal correspondence,} \\ q_{\text{local}}^h, & \text{otherwise.} \end{cases} \quad (12)$$

where h denotes the attention head. Each query determines the attention assigned to its corresponding node type, and the

weighted node representations are aggregated into a single representation $\mathbf{c}_t$ for commit c_t . This allows the model to preserve the distinction between cross-revision evolutionary information and revision-local structural information when representing a commit. Full pooling equations are provided in Appendix F.

Commit-sequence modeling: The resulting commit representations $\langle \mathbf{c}_1, \dots, \mathbf{c}_n \rangle$ are processed by a two-layer Transformer encoder [43]. This allows each candidate commit to be evaluated in the context of the complete candidate history rather than independently.

Commit ranking: A two-layer feed-forward head maps each contextualized commit representation to a scalar score. The highest-scoring candidate is returned as the predicted VIC. Training uses

$$\mathcal{L} = \mathcal{L}_{\text{focal}} + \lambda \mathcal{L}_{\text{margin}}, \quad (13)$$

where $\mathcal{L}_{\text{focal}}$ is focal cross-entropy loss [26] over label-smoothed targets to address class imbalance, and $\mathcal{L}_{\text{margin}}$ encourages the ground-truth VIC to receive a score at least δ greater than the other candidate commits. The complete loss formulation is provided in Appendix F.

5.4 Training Protocol

The two learning stages are trained sequentially. During root-cause line localization, UniXcoder, the projection layer, and graph-attention layers are trained jointly using the pairwise ranking objective, with fixed temporal positional encodings incorporated into the node representations. The bottom eight layers of UniXcoder are frozen to preserve its general-purpose code representations. After this stage converges, the shared graph encoder is frozen, and the commit-level attribution stage trains only the correspondence-aware pooling, commit-sequence Transformer, and ranking head.

Training is supervised using manually verified ground-truth VICs provided in [20], rather than VIC labels generated by SZZ or other positional heuristics. Consequently, the ranking objective does not impose an earliest- or most-recent-commit rule: the model learns to rank the ground-truth VIC highest regardless of where it occurs in the candidate history.

6 Evaluation

We evaluate TraceVIC with respect to our two RQs.

6.1 Dataset and Metrics

Dataset: We evaluate TraceVIC on the Linux kernel vulnerability dataset from Jiang et al. [20], which originally contains 1,349 manually verified VIC instances. The dataset consists of curated triplets of CVEs, VFCs, and their corresponding

ground-truth VICs. Unlike SZZ-generated labels, these inducing commits were manually validated by the original authors through commit history analysis and developer evidence.

Following the filtering process described in Appendix A—including removing oversized files, assembly files, missing repository files, and cases where no candidate commit could be constructed—the final evaluation set contains 780 vulnerability instances.

Metrics: For commit ranking, we report Precision@ k , Recall@ k , F1@ k , and F2@ k for $k \in \{1, 2, 3\}$, measuring how many ground truth VICs are found within the top- k ranked commits:

$$\begin{aligned} P@k &= \frac{\sum_{i=1}^N |\hat{C}_i^k \cap GT_i|}{\sum_{i=1}^N |\hat{C}_i^k|}, & R@k &= \frac{\sum_{i=1}^N |\hat{C}_i^k \cap GT_i|}{\sum_{i=1}^N |GT_i|}, \\ F1@k &= 2 \cdot \frac{P@k \cdot R@k}{P@k + R@k}, & F2@k &= \frac{5 \cdot P@k \cdot R@k}{4 \cdot P@k + R@k} \end{aligned} \quad (14)$$

where $\hat{C}_i^k$ is the set of distinct commits among the top- k ranked predictions for case i , and GT_i is the set of ground truth inducing commits for case i . Full metrics definitions for the rootcause-line ranking stage are provided in Appendix D.

Across all evaluations, we report precision, recall, F1, and F2. While F1 provides a balanced measure of precision and recall, F2 places greater emphasis on recall, which is particularly important for VIC identification because failing to recover the true inducing commit is more consequential than returning additional candidates for manual inspection.

6.2 Experimental Protocol

Evaluation Setup: TraceVIC and NeuralSZZ are learning-based and therefore require training data. Both are evaluated under an identical 5-fold cross-validation procedure over 755 cases remaining after removing 25 duplicated VIC-VFC pairs from the 780-instance filtered dataset. Within each fold, the held-out fold serves as the test set, and the remaining data are split 80/20 into training and validation sets, yielding approximately 483 training cases, 121 validation cases, and 151 test cases per fold. Each case is held out in exactly one fold, so five test folds jointly partition the dataset, and every instance is evaluated exactly once as unseen test data.

Pooled evaluation: We do not average per-fold metrics. Instead, predictions from all five held-out folds are pooled into a single prediction set covering all 755 cases, and the metrics of Eq. 12 are computed once over this pool.

Baseline evaluation: The SZZ-family variants (B-SZZ, V-SZZ, AG-SZZ, MA-SZZ, TSE-SZZ, RA-SZZ, L-SZZ, R-SZZ) are deterministic and untrained; each is executed once over the same 755 cases, yielding predictions directly comparable to the pooled learning-based predictions. The LLM-based methods are stochastic: LLM-SZZ is evaluated with Mistral-7B-Instruct-v0.3 and Gemini 2.5 Pro, while LLM4SZZ and AgenticSZZ are evaluated with Gemini 2.5 pro.

6.3 Impact of Temporal Modeling (RQ1)

We compare TraceVIC against existing VIC identification methods that do not explicitly model the temporal evolution of code changes. Based on their output formulation, we group these methods into three categories: *retrieval-based*, *selection-based*, and *ranking-based* methods. Because these methods produce fundamentally different outputs, we report the results for each category separately. Retrieval-based methods return an unordered set of candidate VICs, selection-based methods produce a single final VIC prediction, and ranking-based methods prioritize candidates according to their likelihood of being the true VIC.

This separation is important because a direct comparison of raw metrics across the three categories would conflate different prediction tasks. Retrieval-based SZZ variants are evaluated on their ability to *retrieve* the true VIC within a candidate set; selection-based approaches are evaluated on their ability to *select* the correct VIC as a single prediction; and ranking-based approaches are additionally evaluated on their ability to *prioritize* the true VIC near the top of the candidate list. For ranking-based methods, we additionally report performance at top-1, top-2, and top-3 to evaluate not only whether the true VIC is recovered, but also how highly it is prioritized.

6.3.1 Retrieval-based Methods

Retrieval-based methods return an unordered set of candidate VICs. A prediction is therefore successful when the ground-truth VIC is contained anywhere in the retrieved candidate set. We evaluate six widely used retrieval-based baselines: B-SZZ, V-SZZ, AG-SZZ, MA-SZZ, TSE-SZZ, and RA-SZZ. These methods primarily differ in how they trace vulnerable lines through the revision history and how they filter the resulting candidate commits. Table 1 summarizes these approaches.

For consistency, we use the implementations of B-SZZ, V-SZZ, AG-SZZ, TSE-SZZ, RA-SZZ and MA-SZZ provided by [19]. All implementations, configurations, and replication materials used in our evaluation are available in our public repository.

Table 2 compares TraceVIC with retrieval-based VIC identification methods. These baselines return sets of candidate commits, which generally favors recall by increasing the likelihood of retrieving the true VIC, but can reduce precision by introducing additional false positives. We therefore report both F1 and F2: F1 captures the balance between precision and recall, while F2 places greater emphasis on recall. We consider recall particularly important in this context because failing to recover the true VIC is more consequential than returning additional candidates for further manual inspection.

TraceVIC achieves a consistently stronger precision–recall trade-off across the evaluated cutoffs. At @1, it achieves the highest precision (0.747), substantially exceeding all retrieval-based baselines. Expanding to @2 increases recall from 0.717

Table 1: Overview of *Retrieval-based methods* for VIC identification.

Method	What it does	Main Distinction	Category
B-SZZ	Uses blame/annotation to trace lines changed by the fixing commit to the most recent commit that modified each line.	Last modification	Baseline tracing heuristic
V-SZZ	Repeatedly traces vulnerable lines backward and identifies the earliest commit that modified the vulnerable code, rather than the most recent one.	Earliest modification	Historical tracing heuristic
AG-SZZ	Extends B-SZZ by filtering non-semantic or cosmetic changes, such as whitespace, comments, and formatting.	Filters cosmetic changes	Candidate-filtering heuristic
MA-SZZ	Extends AG-SZZ by excluding meta-changes, such as branch, merge, and property changes that do not directly modify source behavior.	Filters meta-changes	Candidate-filtering heuristic
TSE-SZZ (VCC)	Extends SZZ by additionally blaming contextual lines surrounding added-only code blocks, under the premise that such additions often represent missing validation checks.	Blames contextual lines	Baseline tracing heuristic
RA-SZZ	Filters candidate commits associated with refactoring operations to avoid identifying behavior-preserving changes as vulnerability-inducing.	Filters refactorings	Candidate-filtering heuristic

Table 2: VIC identification results comparing TraceVIC with *retrieval-based methods*.

Method	Precision	Recall	F1	F2
B-SZZ	0.498	0.693	0.580	0.643
V-SZZ	0.487	0.670	0.564	0.623
AG-SZZ	0.536	0.649	0.587	0.623
MA-SZZ	0.500	0.660	0.569	0.620
TSE-SZZ	0.514	0.719	0.599	0.666
RA-SZZ	0.523	0.607	0.562	0.588
TraceVIC@1	0.747	0.717	0.732	0.723
TraceVIC@2	0.654	0.854	0.741	0.805
TraceVIC@3	0.590	0.909	0.716	0.820

to 0.854 while maintaining precision of 0.654, resulting in the highest F1 score (0.741) and thus the best balance between precision and recall. At @3, TraceVIC further increases recall to 0.909 and achieves the highest F2 score (0.820), while maintaining a precision of 0.590. To compare, the strongest retrieval-based baseline achieves an F1 of 0.599 and an F2 of 0.666.

These results reveal a clear trade-off across the ranking cutoffs: @1 favors precision, @2 provides the best balance between precision and recall, and @3 favors coverage, recovering more than 90% of the ground-truth VICs. Importantly, this increased coverage is achieved with only three ranked candidates, rather than an unrestricted candidate set. Thus, TraceVIC not only improves VIC recovery but also prioritizes the most likely VICs within a small, ranked set, reducing the number of candidates that require further inspection.

6.3.2 Selection-based Methods

Selection-based methods reduce the candidate or revision history to a *single* final VIC prediction. Their evaluation therefore corresponds to a top-1 decision: a prediction is correct if the selected commit matches a ground-truth VIC and incorrect otherwise. We compare TraceVIC against L-SZZ, R-SZZ, LLM-SZZ, AgenticSZZ, and LLM4SZZ under this formulation. L-SZZ and R-SZZ apply explicit heuristics to select one commit from the SZZ candidate set, whereas recent LLM-based approaches use model-guided reasoning over the revision history to produce a final commit prediction. Table 3 summarizes these methods.

The implementations of L-SZZ and R-SZZ are obtained from the replication package of [19]. LLM4SZZ was executed through its own reproducibility package [42], obtained via the artifact of AgenticSZZ [39], which vendors it; we modified only its configuration layer so that repository paths, dataset locations, and the LLM endpoint are supplied through environment variables rather than hardcoded constants, leaving the prompts and algorithm unchanged. AgenticSZZ itself was run from that same artifact, and LLM-SZZ from its publicly available replication package [13], both under their authors’ default configurations.

Table 4 compares TraceVIC with selection-based methods, which identify a single candidate as the predicted VIC. Because these methods produce a single prediction, TraceVIC@1 provides the most direct comparison. TraceVIC@1 achieves a precision of 0.747, recall of 0.717, F1 of 0.732, and F2 of 0.723. It therefore achieves the highest F1 and F2 among the directly comparable methods, while its precision is only slightly below L-SZZ (0.754). In contrast, L-SZZ obtains its high precision at the cost of substantially lower recall (0.485).

TraceVIC@1 also outperforms the recent LLM- and agent-

Table 3: Overview of *Selection-based* methods for VIC identification.

Method	What it does	Main Distinction	Category
L-SZZ	Starts from the SZZ candidate set and selects the candidate commit with the largest amount of code change.	Largest modification	Candidate-selection heuristic
R-SZZ	Selects the most recent candidate among the commits identified by SZZ, producing a single final VIC prediction.	Most recent candidate	Candidate-selection heuristic
LLM-SZZ	Extend V-SZZ with an LLM as the root cause line selection in the previous commit, selecting the most likely root cause line until it reaches the earliest vulnerability-inducing commit.	LLM semantic judgment	LLM-based selection
AgenticSZZ	Temporal Knowledge Graph per fixing commit and expanding the candidate research beyond git blame. An LLM agent navigates then navigates this graph using four tools, reasoning causally to select the single true bug-inducing commit	Candidate space expansion using TKG traversal	Graph-search agentic selection
LLM4SZZ	Uses LLM-guided reasoning over code revisions to identify and return/rank a single final VIC prediction.	LLM semantic judgment	LLM-based selection

Table 4: VIC identification results comparing TraceVIC with *selection-based* methods.

Method	Precision	Recall	F1	F2
L-SZZ	0.754	0.485	0.590	0.522
R-SZZ	0.697	0.448	0.546	0.483
LLM-SZZ (Mistral-7B-v0.3)	0.586	0.486	0.531	0.503
LLM-SZZ (Gemini 2.5 Pro)	0.499	0.683	0.577	0.577
AgenticSZZ (Gemini 2.5 Pro)	0.709	0.681	0.695	0.686
LLM4SZZ (Gemini 2.5 Pro)	0.676	0.705	0.690	0.699
TraceVIC@1	0.747	0.717	0.732	0.723
TraceVIC@2	0.654	0.854	0.741	0.805
TraceVIC@3	0.590	0.909	0.716	0.820

based approaches. Compared with AgenticSZZ, the strongest baseline in terms of F1, TraceVIC@1 improves F1 from 0.695 to 0.732 and F2 from 0.686 to 0.723. Compared with LLM4SZZ, which achieves the highest baseline recall (0.705), TraceVIC@1 improves both precision (0.747 vs. 0.676) and recall (0.717 vs. 0.705). These results indicate that explicitly reasoning over temporal code evolution provides benefits beyond using LLM-based reasoning alone.

Although @1 provides the fairest comparison with selection-based methods, TraceVIC’s ranked output additionally allows analysts to inspect a small number of alternatives. Expanding the cutoff to @2 increases recall to 0.854 and produces the highest F1 (0.741), while @3 reaches 0.909 recall and an F2 of 0.820. Thus, TraceVIC provides both strong single-candidate identification and, when higher coverage is desired, a compact ranked set that substantially increases the likelihood of recovering the true VIC.

6.3.3 Ranking-based Methods

Ranking-based methods differ from the previous two categories by assigning an explicit ordering to candidate VICs. We evaluate whether the ground-truth VIC appears among the top-1, top-2, or top-3 predictions, thereby measuring both candidate recovery and prioritization.

NeuralSZZ requires special treatment because its learned ranking operates at the deletion-line level rather than the commit level. We replicated the authors’ publicly released implementation [41]. To enable a ranking-based comparison without introducing an additional commit-ranking heuristic, we preserve NeuralSZZ’s learned deletion-line ordering and propagate that ordering to the commits obtained through SZZ tracing. Specifically, commits traced from higher-ranked deletion lines receive higher priority in the resulting commit ranking. We consequently evaluate two configurations, NeuralSZZ+B-SZZ and NeuralSZZ+V-SZZ, at top-1, top-2, and top-3. This evaluation preserves NeuralSZZ’s learned ordering while allowing us to assess how effectively its line-level prioritization translates into VIC prioritization at the commit level.

In contrast, TraceVIC is designed to rank candidate commits directly. It first identifies the top- k root-cause deletion lines, constructs temporally connected commit graphs across revisions, and then produces a ranked list of candidate VICs. We evaluate TraceVIC at top-1, top-2, and top-3. Precision@ k measures the proportion of the top- k predictions that correspond to ground-truth VICs, while Recall@ k measures the proportion of ground-truth VICs recovered within the top- k predictions.

As Table 5 reports, compared with NeuralSZZ+B-SZZ, the strongest NeuralSZZ configuration, TraceVIC@1 improves recall from 0.534 to 0.717 and F1 from 0.615 to 0.732 while also slightly improving precision (0.747 vs. 0.724). The difference becomes more pronounced as the ranking depth increases: at @3, TraceVIC reaches 0.909 recall and 0.820

Table 5: VIC identification results comparing TraceVIC with *Ranking-based* NeuralSZZ, assuming that the ranking of deletion lines reflects the ranking of their associated commits.

Method	Precision	Recall	F1	F2
NeuralSZZ+B-SZZ @1	0.724	0.534	0.615	0.564
NeuralSZZ+B-SZZ @2	0.676	0.613	0.643	0.625
NeuralSZZ+B-SZZ @3	0.641	0.636	0.639	0.637
NeuralSZZ+V-SZZ @1	0.713	0.527	0.606	0.556
NeuralSZZ+V-SZZ @2	0.651	0.597	0.622	0.607
NeuralSZZ+V-SZZ @3	0.619	0.618	0.619	0.619
TraceVIC@1	0.747	0.717	0.732	0.723
TraceVIC@2	0.654	0.854	0.741	0.805
TraceVIC@3	0.590	0.909	0.716	0.820

F2, compared with 0.636 and 0.637 for NeuralSZZ+B-SZZ. These results indicate that directly modeling and ranking candidate commits provides substantially stronger VIC prioritization than transferring a learned deletion-line ranking to commits through SZZ tracing.

6.3.4 Ablation: Code-Evolution Modeling

To isolate the contribution of modeling code evolution, we compare TraceVIC against two progressively reduced variants. **Single Revision** restricts the model to a single program revision, removing access to the evolution history. **w/o Temporal Edges** retains the complete sequence of revisions and the same revision-level graph representations and commit-ranking architecture as TraceVIC, but removes the TEMPORAL_FWD and TEMPORAL_BWD edges that explicitly connect corresponding program elements across consecutive revisions. This ablation separates the benefit of reasoning over multiple revisions from the additional benefit of explicitly encoding node-level correspondences across revisions.

Table 6: Ablation study of code-evolution modeling. All results are reported at top-3.

Variant	Precision	Recall	F1	F2
Single Revision	0.637	0.637	0.637	0.637
w/o Temporal Edges	0.604	0.891	0.720	0.814
TraceVIC	0.590	0.909	0.716	0.820

Table 6 shows that access to the evolution history provides the largest improvement. Moving from a single revision to multiple revision-level graphs without explicit temporal edges increases recall from 0.637 to 0.891 and F2 from 0.637 to 0.814, corresponding to relative improvements of 39.9% and 27.8%, respectively. F1 similarly increases from 0.637 to 0.720 (13.0%). These results indicate that vulnerability-inducing changes are more effectively identified when the model can reason over how the relevant code evolves across

multiple revisions rather than relying on a single program snapshot.

Explicit cross-revision correspondences provide a smaller but complementary benefit. Adding TEMPORAL_FWD and TEMPORAL_BWD edges increases recall from 0.891 to 0.909 and F2 from 0.814 to 0.820. This improvement comes with a modest reduction in precision, from 0.604 to 0.590, causing F1 to decrease slightly from 0.720 to 0.716. Thus, temporal edges primarily improve coverage: by directly linking corresponding program elements across consecutive revisions, they help TraceVIC recover additional true VICs that are missed when revisions are represented independently.

The ablation reveals two distinct benefits. Reasoning over the complete revision history accounts for the majority of TraceVIC’s improvement over single-revision analysis, while explicit node-level temporal correspondences provide an additional recall-oriented gain. Relative to the Single Revision variant, the complete TraceVIC model improves recall by 42.7% and F2 by 28.7%. These results support our central hypothesis that reasoning over code evolution improves VIC identification, while further showing that the benefit arises primarily from modeling the broader evolution history rather than from any single temporal mechanism.

Answer to RQ1

Modeling code evolution substantially improves VIC identification. Compared with single-revision reasoning, using the full revision history improves F2 from 0.637 to 0.814, while explicit cross-revision temporal edges further increase F2 to 0.820 and recall to 0.909. TraceVIC also consistently outperforms the strongest baselines under category-appropriate comparisons: @1 for single-selection methods and @k for ranking-based methods. These results show that reasoning over the evolution history is the primary source of improvement, with explicit temporal correspondences providing an additional recall-oriented benefit.

6.4 RQ2: Generalizability

We evaluated TraceVIC generalizability on four popular C/C++ projects: FFmpeg, ImageMagick, OpenSSL, and PHP-SRC. Our evaluation dataset is drawn from the 100 C/C++ vulnerabilities manually verified by Bao et al. [4], excluding Linux kernel cases since our model was trained on them. From the remaining cases, one PHP-SRC instance is further excluded because its fixing commit modifies only M4 autoconf build system files containing no C source changes, yielding 79 test cases across the four projects.

As Table 7 shows, across 79 vulnerabilities from four unseen C/C++ projects, TraceVIC correctly identifies at least one valid VIC for 78 out of 79 cases, demonstrating strong

Table 7: Generalizability results across unseen projects. “Identified CVE” reports CVE-level success, while Precision, Recall, F1, and F2 on top 3 choices are computed at the commit level over all ground-truth VICs.

Project	Total CVE	Identified CVE	GT VICs	Correctly Identified	Precision	Recall	F1	F2
FFmpeg	20	20	27	26	0.867	0.963	0.912	0.942
ImageMagick	20	20	28	24	0.889	0.857	0.873	0.863
OpenSSL	20	20	44	37	0.861	0.841	0.851	0.845
PHP-SRC	19	18	36	26	0.813	0.722	0.765	0.739
Overall	79	78	135	113	0.856	0.837	0.846	0.841

Table 8: Comparison with LLM4SZZ, TSE-SZZ, and NeuralSZZ (+B-SZZ) on the generalizability dataset.

Method	Identified CVE	Precision	Recall	F1	F2
LLM4SZZ	60	0.870	0.444	0.588	0.493
TSE-SZZ	76	0.812	0.607	0.695	0.640
NeuralSZZ+B-SZZ	75	0.918	0.566	0.700	0.613
TraceVIC	78	0.856	0.837	0.846	0.841

transferability beyond the Linux kernel training domain.

Some vulnerabilities are associated with multiple valid inducing commits, resulting in a total of 135 ground-truth VICs across the 79 CVEs. For this reason, we report both CVE-level correctness and commit-level Precision@3, Recall@3, and F1@3. While CVE-level correctness reflects whether at least one true inducing commit is successfully identified, commit-level metrics evaluate how completely the method recovers all valid inducing commits. When multiple VICs exist for a single vulnerability, identifying one correct commit improves CVE-level accuracy, while recall depends on recovering the full set of valid inducing commits.

Among the projects, FFmpeg achieves the strongest performance (F1@3 = 0.912), likely because many vulnerabilities in FFmpeg involve more localized fixes and shorter commit chains, making the causal contribution easier to isolate. ImageMagick and OpenSSL also show strong and stable performance. Although OpenSSL contains the largest number of ground-truth VICs (44 for only 20 CVEs), TraceVIC still maintains high recall (0.841) and F1 (0.851), showing robustness even in projects with deeper histories and more complex vulnerability propagation.

PHP-SRC shows the lowest performance (F1=0.765), likely due to broader code propagation patterns and stronger multi-commit interactions, where vulnerabilities are distributed across larger commit histories. These project-level differences suggest that the main challenge is not the project itself, but the structural complexity of vulnerability evolution within commit histories.

Table 8 further evaluates TraceVIC against the best-performing methods from the retrieval-, selection-, and ranking-based categories on the generalizability dataset: TSE-SZZ, LLM4SZZ, and NeuralSZZ+B-SZZ, respectively. TraceVIC correctly identifies 78 CVEs and achieves the highest

recall (0.837), F1 (0.846), and F2 (0.841), while maintaining high precision (0.856).

Compared with TSE-SZZ, TraceVIC improves both precision (0.856 vs. 0.812) and recall (0.837 vs. 0.607), resulting in a substantial improvement in F1 (0.846 vs. 0.695). This comparison is particularly notable because TSE-SZZ is retrieval-based and can return multiple candidate commits, whereas TraceVIC explicitly ranks candidates according to their likelihood of being the VIC.

The learning-based baselines exhibit a different precision-recall trade-off. NeuralSZZ+B-SZZ achieves the highest precision (0.918), but its recall is substantially lower than TraceVIC’s (0.566 vs. 0.837). Similarly, LLM4SZZ obtains slightly higher precision (0.870 vs. 0.856) but considerably lower recall (0.444 vs. 0.837). Consequently, TraceVIC achieves substantially higher F1 and F2 scores than both methods, indicating that its improvement in VIC recovery does not come at the cost of excessive false positives.

The gains are particularly evident for projects with deeper and more complex revision histories, such as OpenSSL, where vulnerability-relevant code may evolve across multiple commits. These results support the motivation for explicitly modeling code evolution: rather than selecting candidates according to a predefined position in the history, TraceVIC evaluates candidate commits using their structural and temporal context.

To conclude, the results show that TraceVIC’s performance extends beyond the projects used for training and transfers effectively to the unseen projects in the generalizability dataset. Its consistently high recall while preserving strong precision suggests that temporal-structural reasoning remains effective across diverse C/C++ project histories.

We further assess TraceVIC’s computational cost relative to existing approaches and conduct a detailed analysis of its failure cases. Due to space constraints, these analyses are presented in Appendices H and I, respectively.

Answer to RQ2

TraceVIC generalizes effectively beyond its Linux-kernel training domain, identifying at least one valid VIC for 78 of 79 vulnerabilities across four unseen C/C++ projects. It achieves an overall precision of

0.856, recall of 0.837, and F1 of 0.846. Compared with the strongest baseline F1 of 0.700, TraceVIC improves F1 by 20.8%, demonstrating that its temporal reasoning transfers effectively across previously unseen projects.

7 Related Work

VIC identification has evolved from heuristic-based SZZ variants to learning-based and history-aware approaches.

7.1 SZZ Algorithms and Variants

The original SZZ algorithm (B-SZZ) [40] applies `git blame` to lines deleted or modified by a fixing commit and attributes them to their most recent modifiers. Subsequent variants primarily improve candidate filtering or history tracing. AG-SZZ [21], MA-SZZ [10], RA-SZZ [31], and DJ-SZZ [44] progressively filter non-semantic, meta-level, refactoring, and semantics-preserving changes. R-SZZ and L-SZZ [11] select candidates using recency and change-size heuristics, respectively, while V-SZZ [4] traces backward to the earliest reachable modification. TC-SZZ [28] instead retains intermediate commits along the modification history.

Despite these differences, SZZ variants identify VICs through predefined heuristics over the traced history rather than evaluating each candidate’s contribution to the vulnerable condition [18]. TraceVIC instead models this history as an evolution sequence and directly ranks candidate commits using temporal-structural representations.

7.2 Learning-Based SZZ Approaches

Learning-based approaches incorporate richer structural and semantic information. NeuralSZZ [41] uses CodeBERT [14] and graph attention over control- and data-flow relationships to rank root-cause lines, but does not directly rank commits over their evolution history. LLM4SZZ [42] uses LLMs to rank suspicious statements and incorporates commit and patch context, while LLM-SZZ [13] combines code and natural-language context to guide iterative tracing but ultimately selects the earliest reached commit. These methods improve semantic reasoning over individual changes or candidates but do not explicitly model vulnerability-relevant code evolution across the candidate sequence for direct commit ranking.

7.3 Temporal Reasoning over Code History

Recent approaches incorporate software history into fault and vulnerability analysis. FONTE [3] propagates suspiciousness across commit history to rank fault-inducing changes but relies on runtime test coverage. AgenticSZZ [39] represents commit history as a Temporal Knowledge Graph and uses an

LLM agent to reason over relationships among commits, files, functions, and developers. CommitShield [45] incorporates historical context for vulnerability detection but classifies individual commits.

TraceVIC instead models the evolution of vulnerability-relevant code itself by combining within-revision program structure with cross-revision code correspondences and directly ranking candidate VICs without imposing an earliest-or most-recent-commit rule.

8 Threats to Validity

Internal Validity. TraceVIC traces deleted lines for deletion-bearing fixes and nearby anchors for addition-only fixes, focusing the analysis on code associated with the fixing region. Relevant context outside this region may therefore be missed; however, incorporating broader context in our experiments introduced additional false positives and reduced precision. Addition-only fixes introduce further uncertainty because anchor selection may omit relevant histories or introduce unrelated candidates.

Construct Validity. Our evaluation primarily relies on manually verified ground-truth VICs from Jiang et al. [20]; any inaccuracies or subjective attribution decisions are therefore inherited. Candidate construction also depends on successful history tracing, potentially favoring vulnerabilities with cleaner revision histories. Finally, existing methods produce different outputs—candidate sets, single predictions, or rankings. We therefore evaluate these formulations separately, although differences in output semantics may still affect cross-method comparisons.

External Validity. Our primary evaluation uses Linux kernel vulnerabilities, with generalizability evaluated on four unseen C/C++ projects. Thus, although the evaluation covers multiple repositories, the findings may not generalize to other languages or ecosystems. Differences in coding practices, commit granularity, and vulnerability-report quality may also affect performance.

9 Conclusion and Future Work

We reformulate VIC identification as reasoning over code evolution rather than positional selection and introduce **TraceVIC**, a temporal-structural framework that models vulnerability-relevant code across revisions. Our ablation study shows that multi-revision reasoning provides the primary improvement over single-revision analysis, with explicit cross-revision correspondences providing additional gains. TraceVIC outperforms retrieval-, selection-, and ranking-based methods and generalizes to unseen C/C++ projects. Future work will address vulnerabilities induced by interacting commits, complex code changes such as large refactorings, and languages beyond C/C++.

References

- [1] Nikolaos Alexopoulos, Manuel Brack, Jan Philipp Wagner, Tim Grube, and Max Mühlhäuser. How long do vulnerabilities live in the code? a {Large-Scale} empirical measurement study on {FOSS} vulnerability lifetimes. In *31st USENIX Security Symposium (USENIX Security 22)*, pages 359–376, 2022.
- [2] Manar Alohalay and Hassan Takabi. When do changes induce software vulnerabilities? In *2017 IEEE 3rd International conference on collaboration and internet computing (CIC)*, pages 59–66. IEEE, 2017.
- [3] Gabin An, Jingun Hong, Naryeong Kim, and Shin Yoo. Fonte: Finding bug inducing commits from failures. In *2023 IEEE/ACM 45th International Conference on Software Engineering (ICSE)*, pages 589–601. IEEE, 2023.
- [4] Lingfeng Bao, Xin Xia, Ahmed E Hassan, and Xiaohu Yang. V-szz: automatic identification of version ranges affected by cve vulnerabilities. In *Proceedings of the 44th international conference on software engineering*, pages 2352–2364, 2022.
- [5] Markus Borg, Oscar Svensson, Kristian Berg, and Daniel Hansson. Szz unleashed: an open implementation of the szz algorithm-featuring example usage in a study of just-in-time bug prediction for the jenkins project. In *Proceedings of the 3rd ACM SIGSOFT International Workshop on Machine Learning Techniques for Software Quality Evaluation*, pages 7–12, 2019.
- [6] Amiangshu Bosu, Jeffrey C Carver, Munawar Hafiz, Patrick Hilley, and Derek Janni. Identifying the characteristics of vulnerable code changes: An empirical study. In *Proceedings of the 22nd ACM SIGSOFT international symposium on foundations of software engineering*, pages 257–268, 2014.
- [7] Christopher JC Burges. From ranknet to lambdarank to lambdamart: An overview. *Learning*, 11(23-581):81, 2010.
- [8] Xingchu Chen, Chengwei Liu, Jialun Cao, Yang Xiao, Xinyue Cai, Yeting Li, Jingyi Shi, Tianqi Sun, Haiming Chen, and Wei Huo. Vulnerability-affected versions identification: How far are we? In *ASE 2025*, 2025.
- [9] Roland Croft, M Ali Babar, and Huaming Chen. Noisy label learning for security defects. In *Proceedings of the 19th International Conference on Mining Software Repositories*, pages 435–447, 2022.
- [10] Daniel Alencar Da Costa, Shane McIntosh, Weiye Shang, Uirá Kulesza, Roberta Coelho, and Ahmed E Hassan. A framework for evaluating the results of the szz approach for identifying bug-introducing changes. *IEEE Transactions on Software Engineering*, 43(7):641–657, 2016.
- [11] Steven Davies, Marc Roper, and Murray Wood. Comparing text-based and dependence-based approaches for determining the origins of bugs. *Journal of Software: Evolution and Process*, 26(1):107–139, 2014.
- [12] Massimiliano Di Penta, Luigi Cerulo, and Lerina Averzano. The evolution and decay of statically detected source code vulnerabilities. In *2008 Eighth IEEE International Working Conference on Source Code Analysis and Manipulation*, pages 101–110. IEEE, 2008.
- [13] Siqi Fan, Xin Liu, Yingli Zhang, Yuan Tan, Luxing Yin, Zhaorun Chen, Song Li, Lei Qiao, and Rui Zhou. Llm-szz: Novel vulnerability-inducing commit identification driven by large language model and cve description. In *2025 IEEE International Conference on Software Maintenance and Evolution (ICSME)*, pages 48–60. IEEE, 2025.
- [14] Zhangyin Feng, Daya Guo, Duyu Tang, Nan Duan, Xiaocheng Feng, Ming Gong, Linjun Shou, Bing Qin, Ting Liu, Daxin Jiang, et al. Codebert: A pre-trained model for programming and natural languages. In *Findings of the association for computational linguistics: EMNLP 2020*, pages 1536–1547, 2020.
- [15] Daya Guo, Shuai Lu, Nan Duan, Yanlin Wang, Ming Zhou, and Jian Yin. Unixcoder: Unified cross-modal pre-training for code representation. In *Proceedings of the 60th Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, pages 7212–7225, 2022.
- [16] Qixuan Guo and Yongzhong He. Accurate identification of the vulnerability-introducing commit based on differential analysis of patching patterns. In *NDSS*, 2026.
- [17] Steffen Herbold, Alexander Trautsch, Fabian Trautsch, and Benjamin Ledel. Problems with szz and features: An empirical study of the state of practice of defect prediction data collection. *Empirical Software Engineering*, 27(2):42, 2022.
- [18] Torge Hinrichs, Emanuele Iannone, Tamás Aladics, Péter Hegedűs, Andrea De Lucia, Fabio Palomba, and Riccardo Scandariato. Back to the roots: Assessing mining techniques for java vulnerability-contributing commits. *ACM Transactions on Software Engineering and Methodology*, 2024.
- [19] Torge Hinrichs, Emanuele Iannone, Tamás Aladics, Péter Hegedűs, Andrea De Lucia, Fabio Palomba, and Riccardo Scandariato. Back to the roots: Assessing mining techniques for java vulnerability-contributing

- commits. *ACM Transactions on Software Engineering and Methodology*, 35(8):1–41, 2026.
- [20] Muhui Jiang, Jinan Jiang, Tao Wu, Zuchao Ma, Xiapu Luo, and Yajin Zhou. Understanding vulnerability inducing commits of the linux kernel. *ACM Transactions on Software Engineering and Methodology*, 33(7):1–28, 2024.
 - [21] Sunghun Kim, Thomas Zimmermann, Kai Pan, E James Jr, et al. Automatic identification of bug-introducing changes. In *21st IEEE/ACM international conference on automated software engineering (ASE’06)*, pages 81–90. IEEE, 2006.
 - [22] Chris Lattner and Vikram Adve. Llvm: A compilation framework for lifelong program analysis & transformation. In *International symposium on code generation and optimization, 2004. CGO 2004.*, pages 75–86. IEEE, 2004.
 - [23] Triet Huynh Minh Le, Xiaoning Du, and M Ali Babar. Are latent vulnerabilities hidden gems for software vulnerability prediction? an empirical study. In *Proceedings of the 21st International Conference on Mining Software Repositories*, pages 716–727, 2024.
 - [24] Yi Li, Aashish Yadavally, Jiaxing Zhang, Shaohua Wang, and Tien N Nguyen. Commit-level, neural vulnerability detection and assessment. In *Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering*, pages 1024–1036, 2023.
 - [25] Zhen Li, Deqing Zou, Shouhuai Xu, Xinyu Ou, Hai Jin, Sujuan Wang, Zhijun Deng, and Yuyi Zhong. Vuldeep-ecker: A deep learning-based system for vulnerability detection. *arXiv preprint arXiv:1801.01681*, 2018.
 - [26] Tsung-Yi Lin, Priya Goyal, Ross Girshick, Kaiming He, and Piotr Dollár. Focal loss for dense object detection. In *Proceedings of the IEEE international conference on computer vision*, pages 2980–2988, 2017.
 - [27] Qiang Liu, Wenlong Zhang, Muhui Jiang, Lei Wu, and Yajin Zhou. Characteristics, root causes, and detection of incomplete security bug fixes in the linux kernel. *arXiv preprint arXiv:2511.17799*, 2025.
 - [28] Yunbo Lyu, Hong Jin Kang, Ratnadira Widyasari, Julia Lawall, and David Lo. Evaluating szz implementations: An empirical study on the linux kernel. *IEEE Transactions on Software Engineering*, 50(9):2219–2239, 2024.
 - [29] László Nagy. Bear: A tool that generates a compilation database for Clang tooling, 2025. <https://github.com/rizotto/Bear>.
 - [30] National Institute of Standards and Technology. National Vulnerability Database (NVD). <https://nvd.nist.gov>, 2025. Accessed: 2025.
 - [31] Edmilson Campos Neto, Daniel Alencar Da Costa, and Uirá Kulesza. The impact of refactoring changes on the szz algorithm: An empirical study. In *2018 IEEE 25th international conference on software analysis, evolution and reengineering (SANER)*, pages 380–390. IEEE, 2018.
 - [32] Duong Nguyen, Thanh Le-Cong, Triet Huynh Minh Le, M Ali Babar, and Quyet-Thang Huynh. Toward realistic evaluations of just-in-time vulnerability prediction. In *2025 IEEE International Conference on Software Maintenance and Evolution (ICSME)*, pages 1–10. IEEE, 2025.
 - [33] Viet Hung Nguyen and Fabio Massacci. The (un) reliability of nvd vulnerable versions data: An empirical experiment on google chrome vulnerabilities. In *Proceedings of the 8th ACM SIGSAC symposium on Information, computer and communications security*, pages 493–498. ACM, 2013.
 - [34] Andy Ozment and Stuart E Schechter. Milk or wine: does software security improve with age? In *USENIX Security Symposium*, volume 6, pages 10–5555, 2006.
 - [35] Henning Perl, Sergej Dechand, Matthew Smith, Daniel Arp, Fabian Yamaguchi, Konrad Rieck, Sascha Fahl, and Yasemin Acar. Vccfinder: Finding potential vulnerabilities in open-source projects to assist code audits. In *Proceedings of the 22nd ACM SIGSAC conference on computer and communications security*, pages 426–437, 2015.
 - [36] Nam H Pham, Tung Thanh Nguyen, Hoan Anh Nguyen, and Tien N Nguyen. Detection of recurring software vulnerabilities. In *Proceedings of the 25th IEEE/ACM international conference on automated software engineering*, pages 447–456, 2010.
 - [37] Marcus Piancó, Balduino Fonseca, and Nuno Antunes. Code change history and software vulnerabilities. In *2016 46th Annual IEEE/IFIP International Conference on Dependable Systems and Networks Workshop (DSN-W)*, pages 6–9. IEEE, 2016.
 - [38] Giovanni Rosa, Luca Pascarella, Simone Scalabrino, Rosalia Tufano, Gabriele Bavota, Michele Lanza, and Rocco Oliveto. A comprehensive evaluation of szz variants through a developer-informed oracle. *Journal of systems and software*, 202:111729, 2023.

- [39] Yu Shi, Hao Li, Bram Adams, and Ahmed E Hassan. Agenticszz: Temporal knowledge graph-guided agentic bug-inducing commit identification. *arXiv preprint arXiv:2602.02934*, 2026.
- [40] Jacek Śliwerski, Thomas Zimmermann, and Andreas Zeller. When do changes induce fixes? *ACM sigsoft software engineering notes*, 30(4):1–5, 2005.
- [41] Lingxiao Tang, Lingfeng Bao, Xin Xia, and Zhongdong Huang. Neural szz algorithm. In *2023 38th IEEE/ACM International Conference on Automated Software Engineering (ASE)*, pages 1024–1035. IEEE, 2023.
- [42] Lingxiao Tang, Jiakun Liu, Zhongxin Liu, Xiaohu Yang, and Lingfeng Bao. Llm4szz: Enhancing szz algorithm with context-enhanced assessment on large language models. *Proceedings of the ACM on Software Engineering*, 2(ISSTA):343–365, 2025.
- [43] Ashish Vaswani, Noam Shazeer, Niki Parmar, Jakob Uszkoreit, Llion Jones, Aidan N Gomez, Łukasz Kaiser, and Illia Polosukhin. Attention is all you need. *Advances in neural information processing systems*, 30, 2017.
- [44] Chadd Williams and Jaime Spacco. Szz revisited: verifying when changes induce fixes. In *Proceedings of the 2008 workshop on Defects in large software systems*, pages 32–36, 2008.
- [45] Zhaonan Wu, Yanjie Zhao, Chen Wei, Zirui Wan, Yue Liu, and Haoyu Wang. Commitshield: Tracking vulnerability introduction and fix in version control systems. In *2025 IEEE/ACM 47th International Conference on Software Engineering: Companion Proceedings (ICSE-Companion)*, pages 279–290. IEEE, 2025.
- [46] Fabian Yamaguchi, Nico Golde, Daniel Arp, and Konrad Rieck. Modeling and discovering vulnerabilities with code property graphs. In *2014 IEEE symposium on security and privacy*, pages 590–604. IEEE, 2014.
- [47] Xu Yang, Wenhan Zhu, Michael Pacheco, Jiayuan Zhou, Shaowei Wang, Xing Hu, and Kui Liu. Code change intention, development artifact, and history vulnerability: Putting them together for vulnerability fix detection by llm. *Proceedings of the ACM on Software Engineering*, 2(FSE):489–510, 2025.
- [48] Thomas Zimmermann, Rahul Premraj, and Andreas Zeller. Predicting defects for eclipse. In *Third international workshop on predictor models in software engineering (PROMISE’07: ICSE workshops 2007)*, pages 9–9. IEEE, 2007.

Ethical Considerations

This study analyzes publicly available source code, commit histories, and previously disclosed vulnerabilities. It does not involve human participants or interaction with deployed systems. The principal ethical consideration is the potential dual use of vulnerability history analysis. We mitigate this risk by evaluating only previously disclosed vulnerabilities and not releasing undisclosed vulnerability or exploit information.

Open Science

All artifacts required to evaluate the core contributions of this paper including the dataset, source code, pre-trained models, evaluation scripts, configuration files, and documentation are made available via an anonymous repository at <https://anonymous.4open.science/r/TraceVIC/>.

- **Source Code.** Full implementation of the end-to-end VIC identification pipeline, including CPG construction, the Graph Attention Network encoder, and CommitTransformer.
- **Datasets.** All benchmark datasets in preprocessed form, sourced from publicly available repositories, are available.
- **Pre-trained Models.** Model checkpoints for all configurations evaluated in the paper, enabling direct reproduction of reported results without retraining.
- **Evaluation Scripts.** Scripts reproducing all quantitative results, ablation studies, and baseline comparisons, each annotated with expected inputs, outputs, and runtime.
- **Configuration Files.** All hyperparameter settings, model architecture configurations, and training parameters in structured format (YAML/JSON).

The repository includes complete instructions to reproduce all experimental results reported in the paper.

A Dataset Filtering

The original dataset contains 1,349 CVE instances. We applied filtering criteria at each stage of the TraceVIC pipeline, excluding instances that are fundamentally incompatible with our analysis. Table 9 summarizes the filtering process, which reduces the dataset from 1,349 to 780 CVE instances.

Prior to any processing, we excluded 89 instances where the relevant source files exceed 5,000 lines of code. In these cases, the vulnerability-inducing commit corresponds to the initial commit in which all code was first introduced into the file, making commit-level differentiation impossible regardless of the method applied.

At the graph construction stage, we excluded 15 instances involving assembly files, as the graph construction pipeline is designed for C source code and does not extend to assembly-level analysis. We additionally excluded 25 instances where the files referenced in the fixing commit are absent from the repository, preventing graph construction entirely.

At the V-SZZ traversal stage, we excluded 440 instances where the fixing commit SZZ traversal did not produce any candidate vulnerability-inducing commit. Without a candidate commit chain, commit ranking cannot be performed.

Table 9: Dataset Filtering Summary

Filtering Criterion	Instances Excluded
Source files exceeding 5,000 lines	89
Assembly files	15
Missing repository files	25
No candidate commit	440
Original Dataset	1,349
Final Dataset	780

B CPG Construction

Compilation Context Reconstruction

C programs depend heavily on preprocessing, header inclusion, and compiler-specific configurations, making accurate analysis contingent on reconstructing the full compilation context. Without this context, header dependencies remain unresolved, leading to incorrect or incomplete ASTs. TraceVIC addresses these challenges by explicitly reconstructing compilation environments using Bear [29], which intercepts the build process and records compilation commands, including header paths, preprocessor definitions, and compiler flags, producing a `compile_commands.json` database.

Semantic Unit Extraction

With the compilation database in place, TraceVIC uses Clang [22] to parse each C source file into an AST, from which it extracts semantic units that serve as graph nodes. These units include function declarations, control structures, and expressions, providing a structured representation at the level of granularity required for vulnerability analysis. We adopt AST-level granularity (statements and expressions) as it provides a balance between semantic expressiveness and computational tractability. Because the full compilation context has been reconstructed, the Clang–Bear integration resolves C-specific constructs such as struct definitions, pointer operations, macro expansions, and preprocessor directives, so the extracted representation faithfully captures the true semantics of the code.

Control and Data Flow Extraction

Semantic nodes alone are insufficient to reason about vulnerability behavior, as vulnerabilities arise not from isolated code elements but from how they interact. TraceVIC uses Joern [46] to extract Control Flow Graph (CFG) and Data Flow Graph (DFG) edges from the parsed C code, encoding execution order and variable dependencies respectively. Joern’s default representation operates at the token level; TraceVIC discards Joern’s node representation and retains only the extracted flow edges, which are then integrated with the higher-level semantic units derived from Clang.

Semantic-Flow Fusion and Refinement

TraceVIC integrates Clang nodes and Joern edges into a unified CPG by aligning both representations at the source line level. For each flow edge identified by Joern, the corresponding Clang AST units are located and a directed edge is introduced between them. The unified graph is then filtered using the fixing commit’s diff: only nodes corresponding to lines present in the diff are retained, focusing the representation on vulnerability-relevant code changes.

C Node Correspondence Matching

For each history entry $h_t = (\text{line_num}_t, \text{code}_t)$ produced by V-SZZ for a given revision c_t , TraceVIC identifies the corresponding node $v \in V_t$ in the CPG of that revision using a three-level priority cascade.

Level 1 (line range and code prefix). A node v is selected if h_t ’s line number falls within v ’s line range and a prefix of length λ of h_t ’s code appears in v ’s code, or vice versa:

$$\begin{aligned} \text{lineBeg}(v) \leq \text{line_num}_t \leq \text{lineEnd}(v) \\ \text{and } (\text{code}_t[:\lambda] \subseteq v.\text{code} \vee v.\text{code}[:\lambda] \subseteq \text{code}_t) \end{aligned} \quad (15)$$

Level 2 (line range only). If no Level 1 match is found, TraceVIC selects any node v satisfying $\text{lineBeg}(v) \leq \text{line_num}_t \leq \text{lineEnd}(v)$. This handles cases where minor code reformatting prevents exact prefix matching.

Level 3 (code prefix only). If neither Level 1 nor Level 2 yields a match, TraceVIC selects any node v satisfying the code prefix condition above. This handles cases where line numbers shift due to insertions or deletions in adjacent code.

If none of the three levels produces a match for a given revision, no temporal edge is added for that revision pair. When a revision’s CPG is empty, TraceVIC inserts a synthetic node with the line number and code content from the history entry to preserve chain connectivity. We use $\lambda = 20$ characters throughout all experiments.

D Evaluation Metrics

Root Cause Line Identification. We report Precision, Recall, and F1-Score at ranks 1, 2, and 3. Precision@ k measures the proportion of the top- k ranked lines that are true root cause lines. Recall@ k measures the proportion of true root cause lines successfully identified within the top- k ranked lines. F1@ k is the harmonic mean of Precision@ k and Recall@ k .

$$P@k = \frac{1}{N} \sum_{i=1}^N \frac{|\{\text{rank}_1^{(i)}, \dots, \text{rank}_k^{(i)}\} \cap GT_i|}{k} \quad (16)$$

$$R@k = \frac{1}{N} \sum_{i=1}^N \frac{|\{\text{rank}_1^{(i)}, \dots, \text{rank}_k^{(i)}\} \cap GT_i|}{|GT_i|} \quad (17)$$

$$F1@k = 2 \cdot \frac{P@k \cdot R@k}{P@k + R@k} \quad (18)$$

where N is the total number of test cases, GT_i is the set of ground truth root cause lines for test case i , and $\text{rank}_j^{(i)}$ is the j -th ranked line for test case i .

E Graph Encoder Equations

This appendix provides the full equations for the edge-aware graph-attention layer described in Section 5.

Input projections. For each node i at head h :

$$Q_i^h = h_i W_Q^h, \quad K_i^h = h_i W_K^h, \quad V_i^h = h_i W_V^h \quad (19)$$

where $W_Q^h, W_K^h, W_V^h \in \mathbb{R}^{d \times d_h}$ and $d_h = d/H$.

Edge-type-biased attention. For each directed edge ($j \rightarrow i$):

$$e_{ij}^h = (Q_i^h \cdot K_j^h) \cdot d_h^{-\frac{1}{2}} + b_{tij}^h \quad (20)$$

where $t_{ij} \in \{0, \dots, 6\}$ is the edge type index and b_{tij}^h is a learned scalar drawn from an embedding table $\mathbf{B} \in \mathbb{R}^{7 \times H}$.

Normalization and aggregation.

$$\alpha_{ij}^h = \frac{\exp(e_{ij}^h)}{\sum_{k \in \mathcal{N}(i)} \exp(e_{ik}^h)} \quad (21)$$

$$z_i^h = \sum_{j \in \mathcal{N}(i)} \alpha_{ij}^h V_j^h \quad (22)$$

Output projection and residual.

$$h_i' = \text{LayerNorm}\left(h_i + \text{Dropout}\left(W^O(z_i^1 \parallel \dots \parallel z_i^H)\right)\right) \quad (23)$$

$$h_i'' = \text{LayerNorm}\left(h_i' + \text{Dropout}\left(W_2 \text{GELU}(W_1 h_i')\right)\right) \quad (24)$$

where $W_1, W_2 \in \mathbb{R}^{d \times d}$. TraceVIC applies $L = 2$ layers in all experiments.

F Commit Attribution Equations

This appendix provides the full equations for the commit attribution stage described in Section 5.3.

Input Projection

Node embeddings from the frozen encoder ($\mathbb{R}^{768}$) are projected to the internal dimension d' :

$$\tilde{h}_v = \text{Dropout}(\text{GELU}(\text{LayerNorm}(W_{\text{in}} h_v''))) \quad (25)$$

where $W_{\text{in}} \in \mathbb{R}^{768 \times d'}$.

Correspondence-Aware Attention Pooling

Keys and values are projected for all nodes:

$$K_v^h = \tilde{h}_v W_K^h \in \mathbb{R}^{d_h'}, \quad V_v^h = \tilde{h}_v W_V^h \in \mathbb{R}^{d_h'} \quad (26)$$

where $d_h' = d'/H$. Each node is assigned a query based on its role:

$$q_v^h = \begin{cases} q_{\text{corr}}^h & \text{if } v \text{ is a TEMPORAL_FWD target} \\ q_{\text{local}}^h & \text{otherwise} \end{cases} \quad (27)$$

where $q_{\text{corr}}^h, q_{\text{local}}^h \in \mathbb{R}^{d_h'}$ are learned parameters. Attention logits and weights, normalized over all nodes in commit c_t :

$$e_v^h = (q_v^h \cdot K_v^h) \cdot d_h'^{-\frac{1}{2}} \quad (28)$$

$$\alpha_v^h = \frac{\exp(e_v^h)}{\sum_{u \in \mathcal{S}(c_t)} \exp(e_u^h)}, \quad v \in \mathcal{S}(c_t) \quad (29)$$

Per-head commit embeddings are aggregated and projected:

$$\mathbf{c}_t^h = \sum_{v \in \mathcal{S}(c_t)} \alpha_v^h V_v^h \quad (30)$$

$$\mathbf{c}_t = \text{LayerNorm}(W_O(\mathbf{c}_t^1 \parallel \dots \parallel \mathbf{c}_t^H)) \in \mathbb{R}^{d'} \quad (31)$$

Commit-Level Transformer

Self-attention over the commit sequence:

$$e_{ts} = \frac{(\mathbf{c}_t W_Q)(\mathbf{c}_s W_K)^T}{\sqrt{d_h'}}, \quad \alpha_{ts} = \frac{\exp(e_{ts})}{\sum_r \exp(e_{tr})} \quad (32)$$

$$\mathbf{c}_t' = \text{LayerNorm}\left(\mathbf{c}_t + \text{Dropout}\left(W_O \sum_s \alpha_{ts} \mathbf{c}_s W_V\right)\right) \quad (33)$$

$$\mathbf{c}_t'' = \text{LayerNorm}(\mathbf{c}_t' + \text{Dropout}(\text{FFN}(\mathbf{c}_t'))) \quad (34)$$

where $\text{FFN}(x) = W_2 \text{GELU}(W_1 x)$ with hidden dimension $4d'$.

Ranking Head

$$s_t = W_2 \cdot \text{Dropout}(\text{GELU}(W_1 \mathbf{c}_t'')) \quad (35)$$

where $W_1 \in \mathbb{R}^{d' \times d'/2}$ and $W_2 \in \mathbb{R}^{d'/2 \times 1}$.

Loss Function

Soft targets. For C candidate commits with ground-truth set G and smoothing factor ε :

$$\tilde{y}_t = \begin{cases} \frac{1-\varepsilon}{|G|} & t \in G \\ \frac{\varepsilon}{C-|G|} & t \notin G \end{cases}, \quad \tilde{y}_t \leftarrow \frac{\tilde{y}_t}{\sum_j \tilde{y}_j} \quad (36)$$

Predicted probabilities.

$$p_t = \frac{\exp(s_t/\tau)}{\sum_{j=1}^C \exp(s_j/\tau)}, \quad \bar{p}_{\text{gt}} = \frac{1}{|G|} \sum_{t \in G} p_t \quad (37)$$

Focal cross-entropy loss.

$$\mathcal{L}_{\text{focal}} = \alpha \cdot (1 - \bar{p}_{\text{gt}})^\gamma \cdot \left(- \sum_{t=1}^C \tilde{y}_t \log(p_t + \varepsilon) \right) \quad (38)$$

Margin loss. Let $N = \{1, \dots, C\} \setminus G$:

$$\mathcal{L}_{\text{margin}} = \frac{1}{|G| \cdot |N|} \sum_{i \in G} \sum_{j \in N} \max(0, \delta - (s_i - s_j)) \quad (39)$$

Combined loss.

$$\mathcal{L} = \mathcal{L}_{\text{focal}} + \lambda \mathcal{L}_{\text{margin}} \quad (40)$$

TraceVIC uses $\tau = 0.1$, $\varepsilon = 0.05$, $\gamma = 2.0$, $\alpha = 1.0$, $\delta = 0.5$, and $\lambda = 0.5$ in all experiments.

G Addition Cases Structural Pattern

Manual analysis of addition-only CVEs turned up one recurring shape:

ROLE	STATUS IN PRE-FIX FILE
Anchor operation	present
Missing companion	<i>absent</i> , added by the fix
Downstream operation	present

The vulnerability is the absence of the companion statement (a bounds check, a resource release, a lock guard), not an error in the anchor. The VIC is the commit that introduced the anchor operation without its required companion, so blaming the anchor line, rather than a deleted line that does not exist, traces directly to it.

Extraction procedure. For each contiguous block of added lines, we extract up to three anchor lines from the post-fix file: lines already present in the pre-fix version that sit next to, or enclose, the insertion point.

- **Above:** the nearest non-noise line preceding the block, for *missing-cleanup* defects (the fix adds a release for a resource acquired above).

CVE-2016-3135 netfilter / xt_alloc_table_info / missing guard

```
size_t sz = sizeof(*info) + size; [above]
+ if (sz < sizeof(*info))
+   return NULL;
if ((SMP_ALIGN(size) >> ...)) [below]
```

↪ VIC 711bdde6a884

CVE-2022-20423 usb/rndis / rndis_set_response / missing guard

```
if ((BufLength > MAX_TOTAL_SIZE) || [above]
+   (BufOffset > MAX_TOTAL_SIZE) ||
+   (BufOffset + 8 >= MAX_TOTAL_SIZE)) [below]
```

↪ VIC 38ea1eac7d88

CVE-2019-19074 ath9k / ath9k_wmi_cmd / missing cleanup

```
mutex_unlock(&wmi->op_mutex); [above]
+ kfree_skb(skb);
return -ETIMEDOUT; [noise, skipped]
```

↪ VIC fb9987d0f748

Figure 3: Anchor-line extraction for three addition-only VFCs. TraceVIC identifies nearby pre-existing code as anchors for tracing the vulnerability-relevant revision history.

- **Below:** the nearest non-noise line following the block, for *missing-guard* defects (the fix adds a check for an operation present below).
- **Signature:** the enclosing function signature, located by scanning upward with brace-depth tracking. A function signature is rarely modified after the VIC introduces it, so it works as a stable fallback when neighbouring lines are noise or post-date the VIC.

A noise filter strips structural boilerplate (`goto`, `return -ERRNO`, labels, braces, `break/continue`) so anchors land on meaningful code rather than scaffolding. Anchors are deduplicated, and mapped from post-fix to pre-fix line coordinates. Each is emitted as a synthetic deletion line in $\mathcal{D}'(V)$, so the candidate-chain construction (Eq. 1–2) and everything downstream run without modification.

Figure 3 illustrates anchor extraction for three addition-only fixes and shows why multiple anchor types are considered: depending on the structure of the fix, different anchors may provide access to the vulnerability-relevant history.

CVE-2016-3135 (netfilter, xt_alloc_table_info). The fix inserts an integer-overflow guard. The ABOVE anchor, the overflowing computation `sz = sizeof(*info) +`

size, traces to the ground-truth VIC (711bdde6a884); the BELOW anchor does not. This is the case for extracting more than one anchor type: relying on just one would have missed it here.

CVE-2022-20423 (USB RNDIS, `rndis_set_response`). The fix adds a missing bounds-check clause to an existing compound if. Both anchors trace to 38ea1eac7d88. The fixing commit’s own message reads Fixes: 38ea1eac7d88, a kernel-maintainer attribution independent of our dataset, and it matches our prediction exactly.

CVE-2019-19074 (`ath9k`, `ath9k_wmi_cmd`). The fix inserts a single `kfree_skb(skb)` to close a memory leak. The ABOVE anchor traces to fb9987d0f748, the ground-truth VIC. The nearest BELOW candidate, `return -ETIMEDOUT`, is dropped by the noise filter: without filtering, error-handling boilerplate like this would dilute the candidate pool. The two surviving anchors agree, leaving a pool of exactly one commit.

H Computational Cost

Accuracy is only part of the practical picture: a method that must be re-run whenever new vulnerabilities are disclosed is limited as much by its cost per query as by its precision. We therefore measured wall-clock time for TraceVIC and the two strongest LLM-based baselines over the same 755 Linux kernel cases. TraceVIC was run on a single NVIDIA RTX 4090 GPU; the LLM baselines were served by Gemini 2.5 Pro under their authors’ default configurations, so their timings reflect API latency rather than local computation.

Figure 4 reports cumulative CVEs analyzed against elapsed time. TraceVIC ranks all 755 cases in 4.4 minutes—0.35 seconds per case—compared with 10.8 hours for AgenticSZZ and 28.7 hours for LLM4SZZ, speedups of roughly 147× and 391× respectively. The gap arises from where the analysis cost is incurred. The LLM-based methods issue repeated model queries per case: AgenticSZZ traverses its temporal knowledge graph through successive agent tool calls, and LLM4SZZ performs iterative context-enhanced assessment over candidate commits. Both incur a network-bound, per-case cost that recurs on every invocation and scales with the length of the candidate commit chain. TraceVIC instead front-loads its cost: graph construction and node encoding are performed once per repository revision and cached, after which ranking a vulnerability requires a single forward pass over the cached temporal subgraphs.

I Failure Analysis

We manually analyzed 21 failure cases where TraceVIC failed to correctly identify the VICs in the Linux kernel dataset to better understand the main sources of error. The most com-

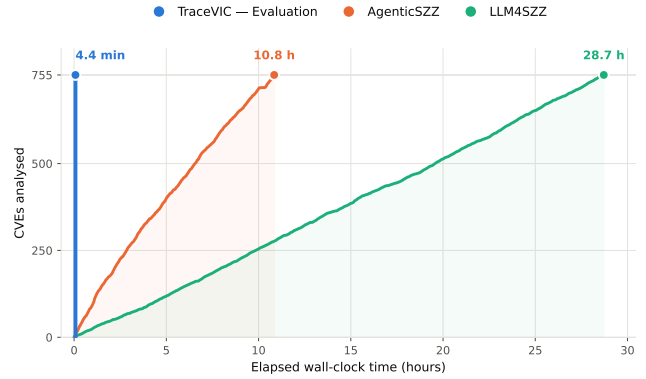


Figure 4: Cumulative CVEs analyzed against elapsed wall-clock time over the 755-case Linux kernel dataset.

mon failure pattern was commits with a large number of deleted lines (7 cases, 1.1%), followed by large refactoring performed together with the fix (6 cases, 0.9%). Vulnerability propagation through later refactoring accounted for 3 cases (0.4%), while code movement without actual code changes and downstream extensions each appeared in 2 cases (0.3%). Overall, most failures occur when strong surrounding structural changes overshadow the true vulnerability signal.

- **Large number of deleted lines:** VFCs containing many deleted lines make root cause identification more difficult. When 16 or more lines are deleted, the large number of non-root-cause deletions introduces substantial noise, diluting the signal of the true root cause and making it harder for the model to isolate the semantically critical line.
- **Large refactoring with the fix:** When developers fix a vulnerability while also performing major code cleanup or refactoring, the structural changes produce stronger representational signals than the actual vulnerability fix. As a result, the model may prioritize refactoring deletions over the true root cause.
- **Code movement without code change:** In some cases, the bug is fixed only by reordering lines rather than changing code content. Larger co-moved blocks create stronger signals than the isolated root cause line, causing the model to rank them higher.
- **Downstream extensions masking the origin:** Later commits may extend the vulnerable design by adding more related code around it. These commits create stronger lexical and structural overlap with the fixing commit than the true VIC, leading to incorrect attribution.
- **Vulnerability propagated by later refactoring:** When a later refactoring preserves the vulnerable line unchanged but restructures the surrounding function, the stronger contextual similarity with the fixing commit can displace the true origin commit in the ranking.

These results show that TraceVIC is most challenged when the true vulnerability signal is hidden by larger structural changes, especially large refactorings and noisy deletion-heavy fixes. Future work should focus on improving robustness to such cases by incorporating finer-grained semantic change analysis that can better separate true causal changes from surrounding refactoring noise.